PLAN DE VISITA

SPIKA TECH, S.L.

Nº PROYECTO DE CERTIFICACIÓN	TIPO DE ACTIVIDAD	NORMA DE APLICACIÓN O REGLAMENTO	FECHAS
2024/0175/SI/01	FASE 2	UNE-EN ISO/IEC 27001:2022	2025-04-21, 22 y 23

Referencia: SFB/AGA
Fecha: 2023-05-23 Revisión 0:

DATOS DE LA EMPRESA

ORGANIZACIÓN/EMPRESA: SPIKA TECH, S.L.
REPRESENTANTE DE LA DIRECCIÓN: Dña. D. CARLOS ZÚÑIGA ARNAU

DATOS DEL EQUIPO AUDITOR

MIEMBROS DEL EQUIPO
Auditor Jefe: Maximiliano Tagua (MTD)

DURACIÓN DE LA AUDITORÍA:

Duración total de auditoría in-situ:	2.5	Nº jornadas en remoto (si aplica):	

FUNCIONES Y RESPONSABILIDADES

- Auditor Jefe: Dirige reuniones inicial y final, coordina equipo auditor y es responsable del contenido del informe.
- Auditor: Participa en el desarrollo de la auditoría según las pautas del Auditor Jefe.
- Auditor Jefe en prácticas: En proceso de calificación como auditor jefe. Las mismas funciones y responsabilidades del Auditor Jefe, pero supervisado por éste
- Auditor en prácticas: En proceso de calificación como auditor. Las mismas funciones y responsabilidades del Auditor, pero supervisado por éste.
- Observador: Asiste al desarrollo de la auditoría sin intervenir en ella por distintos posibles motivos (calificación, supervisión, acompañamiento de entidad acreditadora…) que deberán ser comunicados a la Organización con anterioridad a la auditoría.
- Experto: Como apoyo al equipo auditor en relación con determinados conocimientos específicos

DIRECCIONES DE LOS CENTROS A AUDITAR

1) Avenida Alcalde de Móstoles, s/n Universidad Rey Juan Carlos, Campus de Móstoles, Laboratorio III, Aula S009 (Sótano)

OBJETIVOS Y ALCANCE DE LA AUDITORÍA

Los objetivos de la auditoría son:

- Determinar la conformidad del sistema de gestión de la organización / empresa auditada con los criterios de auditoría para la realización de la auditoria FASE 2

Esta evaluación se realizará para las actividades de:

Los sistemas de información que da soporte a los procesos:
- Diseño, desarrollo, implantación y servicio postventa de software de apoyo para la captura de datos y gestión del mantenimiento.
Definición, optimización e implantación de procesos de fabricación. Según declaración de aplicabilidad vigente a fecha de emisión del certificado

con el fin de determinar el nivel de implantación y cumplimiento de los requisitos de la/s norma/s/reglamentos de referencia.

Especificar si existieran otros objetivos específicos para la auditoría: N/A

FECHA INICIO AUDITORÍA: 2025-04-21

FECHA FIN AUDITORÍA: 2025-04-23

NOTAS:
1. Toda la documentación que se emplee o se genere durante la auditoría tiene carácter confidencial, no pudiendo transcribirse a terceros o reproducirse sin permiso expreso de la empresa. 2. La **reunión inicial** tiene como fin presentar el equipo auditor a la empresa (dirección y responsables de departamentos, áreas, etc.), explicando sus funciones y responsabilidades. Deben tratarse, en la medida en que sea procedente, además los siguientes aspectos: - Presentación de las actividades que se desarrollan en AENOR INTERNACIONAL S.A.U. - Confirmar del objeto, alcance y sistemática a utilizar durante la auditoría. - Revisar y modificar (si procede) el plan de auditoría, entendiendo por modificaciones aquellos ajustes que se realicen por disponibilidad de los departamentos/personas a auditar. - Confirmar los canales de comunicación formales entre el equipo auditor y el cliente. - Confirmar que están disponibles los recursos y la logística necesaria para el equipo auditor. - Confirmar los procedimientos de protección, emergencia y seguridad en el trabajo pertinentes para el equipo auditor. - Realizar aclaraciones al proceso de Certificación de Sistemas (en base al cual se realice la auditoría), como son: temas relativos a la confidencialidad; método de presentación de la información, incluyendo la sistemática de categorización de hallazgos. - Informar al cliente de las circunstancias bajo las cuáles la auditoría puede darse por terminada de forma prematura (por ejemplo: falta de implantación del sistema, no disponibilidad de determinados responsables, imposibilidad de auditar determinados procesos o requisitos…). - Confirmar el estado de los hallazgos de la revisión o auditoría anterior, cuando corresponda. - Informar al cliente sobre el carácter muestral inherente al propio proceso de auditoría. - Confirmar el idioma que se va utilizar durante la auditoría, cuando proceda. - Dar la oportunidad al cliente para realizar ruegos y preguntas. 3. La reunión final tiene por objeto dar lectura al informe de auditoría donde se reflejan los resultados de la auditoría. Deberían estar presentes las mismas personas indicadas en la reunión inicial. 4. El equipo auditor debe disponer de una sala o similar donde realizar sus reuniones. Estas se celebrarán al final de cada jornada y su duración se estima en 30 minutos. Asimismo, se pondrá a disposición del equipo auditor un juego completo de la Documentación del Sistema de Gestión. 5. El orden y horario indicados en la matriz de actividades son orientativos y pueden modificarse durante el desarrollo de la auditoría, en función de su evolución. El horario de la comida se ajustará al de la empresa, si bien se estima aproximadamente 1 hora entre las 14:30 y 15:30. 6. En caso de recusación de auditores rogamos nos lo comuniquen con la mayor brevedad posible. 7. Los requisitos a tener en cuenta durante la auditoría son los establecidos en la documentación del sistema de gestión de la empresa, la norma de referencia y el reglamento de certificación.

ANEXO - ASPECTOS ESPECÍFICOS PARA LA MATRIZ DE PLANIFICACIÓN ISO/IEC 27001:2022 (SISTEMAS DE GESTIÓN PARA LA SEGURIDAD DE LA INFORMACIÓN)

1. Aparecen marcados con "X" los departamentos/procesos y requisitos que está previsto auditar.

2. Aparecen en negrita los requisitos que serán evaluados en todas las auditorías del ciclo ordinario de certificación. Los requisitos que aparecen sombreados se auditarán por un auditor especialista.

3. La auditoría del apartado 7.5 "Información documentada" incluirá los subapartados 7.5.1 "Consideraciones Generales", 7.5.2 "Creación y Actualización" y 7.5.3 "Control de Información Documentada". En caso de existir no conformidades al apartado 7.5, éstas se asignarán al correspondiente subapartado de la norma, indicándolo así en el cuadro de redacción de No Conformidades del Informe de Auditoría.

4. Durante la auditoría del apartado 5 "Liderazgo" debería estar presente la Alta Dirección de la Organización.

5. A lo largo de la auditoría se comprobará el cierre de las acciones correctivas derivadas de los informes de fase I, fase II o auditorías anteriores según proceda y la corrección de las observaciones. Así mismo se comprobará la adecuación de los cambios documentales habidos desde la auditoría anterior.

6. En organizaciones certificadas, durante toda la auditoría se verificará en los diferentes departamentos auditados el Uso de la Marca AENOR.

7. Se auditará el tratamiento de las reclamaciones de terceros (si existieran), especificando la reclamación y el momento y responsable con el que se audita.

Nota: El equipo auditor verificará el cumplimiento del Sistema de Gestión de Seguridad de la Información de la organización contra los apartados de la norma de referencia y, además, realizará pruebas de cumplimiento de los objetivos de control y controles implantados en la organización

Para ello, el equipo auditor seleccionará las pruebas de cumplimiento a realizar sobre los controles implantados en base al análisis de riesgos y a la declaración de aplicabilidad vigente y el ANEXO A de la norma **ISO/IEC 27001:2022**

ANEXO - MATRIZ ACTIVIDADES DE AUDITORÍA

ISO/IEC 27001:2022 Sistema de Gestión de Seguridad de la Información					4 CONTEXTO DE LA ORGANIZACIÓN	4.1 Comprensión de la organización y de su contexto	4.2 Comprensión de las necesidades y expectativas de las partes interesadas	4.3 Determinación del alcance del sistema de gestión de seguridad de la información	4.4 Sistema de gestión de seguridad de la información	5 LIDERAZGO	5.1 Liderazgo y compromiso	5. 2 Política	5.3 Roles, responsabilidades y autoridades en la organización	6 PLANIFICACIÓN	6.1 Acciones para tratar los riesgos y oportunidades	6.1.1 Consideraciones Generales	6.1.2 Apreciación de riesgos de seguridad de la información	6.1.3 Tratamiento de los riesgos de seguridad de la información	6.2 Objetivos de seguridad de la información y planificación para su consecución	7 SOPORTE	7.1 Recursos	7.2 Competencia	7.3 Concienciación	7.4 Comunicación	7.5 Información Documentada	7.5.1 Consideraciones Generales	7.5.2 Creación y actualización	7.5.3 Control de información documentada	8 OPERACIÓN	8.1 Planificación y Control Operacional	8.2 Apreciación de los riesgos de seguridad de información	8.3 Tratamiento de los riesgos de seguridad de información	9 EVALUACIÓN DEL DESEMPEÑO	9.1 Seguimiento, medición, análisis y evaluación	9.2 Auditoría interna	9.3 Revisión por la Dirección	10 MEJORA	10.1 No conformidad y acciones correctivas	10.2 Mejora Continua
DÍA	**CENTRO**	**HORA**	**AUDITOR**	**PROCESO/ DEPARTAM/ DOCUMENTO/ ACTIVIDAD**																																				
1	1	09:00 a 09:30	MTD	**REUNIÓN INICIAL**																																				
1	1	09:30 a 14:00	MTD	Gobierno Seguridad de la Información	X	X	X	X	X	X	X	X		X	X	X			X						X	X	X	X												
				RR.HH. / Comunicación /Controles									X							X	X	X	X	X																
				Desempeño y mejora Riesgos /Controles													X	X													X	X	X	X	X	X	X	X	X
1	1	15:00 a 18:00	MTD	Operaciones/Controles																									X	X										
2	1	09:00 a 18:00	MTD	Operaciones/Controles																									X	X										
3	1	10:00 a 13:30	MTD	**Temas pendientes + Elaboración Informe**																																				
3	1	13:30 a 14:00	MTD	**Lectura Informe**																																				

ISO/IEC 27001:2022 (GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN) (Continuación)					5.Controles de la organización	6.Controles de las personas	7.Controles Físicos	8.Controles tecnológicos
DÍA	**CENTRO**	**HORA**	**AUDITOR**	**PROCESO/ DEPARTAM/ DOCUMENTO/ ACTIVIDAD**				
1	1	09:00 a 14:00	MTD	SISTEMA DE GESTIÓN	X	X	X	X
1	1	15:00 a 18:00	MTD	CONTROLES / ANEXO A	X	X	X	X
2	1	09:00 a 18:00	MTD	CONTROLES / ANEXO A	X	X	X	X
3	1	10:00 a 13:30	MTD	**Elaboración Informe**				
3	1	13:30 a 14:00	MTD	**Lectura Informe**				

AUDITORÍA PRESENCIAL: 2.5 JORNADAS

APTDO.	REQUISITO	FASE I	FASE II	AS1	AS2	REN
5.1	Políticas de seguridad de la información		X			
5.2	Funciones y responsabilidades en seguridad de la información		X			
5.3	Segregación de tareas		X			
5.4	Responsabilidades de gestión		X			
5.5	Contacto con las autoridades		X			

5.6	Contacto con grupos de interés especial	X
5.7	Información sobre Amenazas	X
5.8	Seguridad de la información en la gestión de proyectos	X
5.9	Inventario de información y otros activos asociados	X
5.10	Uso aceptable de la información y otros activos asociados	X
5.11	Devolución de activos	X
5.12	Clasificación de la información	X
5.13	Etiquetado de la información	X
5.14	Transferencia de la información	X
5.15	Control de acceso	X
5.16	Gestión de la Identidad	X
5.17	Información de autentificación	X
5.18	Derechos de acceso	X
5.19	Seguridad de la Información en las relaciones con los proveedores	X
5.20	Abordar la seguridad de la información en los acuerdos con los proveedores	X
5.21	Gestión de la seguridad de la información en la cadena de suministro de las TIC	X
5.22	Seguimiento, revisión y gestión de cambios de los servicios de los proveedores	X
5.23	Seguridad de la información para el uso de servicios en la nube	X
5.24	Planificación y preparación de la gestión de incidentes de seguridad de la información	X
5.25	Evaluación y decisión sobre eventos de seguridad de la información	X
5.26	Respuesta a los incidentes de seguridad de la información	X
5.27	Aprender de los incidentes de seguridad de la información	X
5.28	Recopilación de pruebas	X
5.29	Seguridad de la información durante la interrupción	X
5.30	Preparación de las TIC para la continuidad de la actividad	X
5.31	Identificación de los requisitos legales, reglamentarios y contractuales	X
5.32	Derechos de propiedad intelectual (DPI)	X
5.33	Protección de los registros	X
5.34	Protección de datos y privacidad de la información de carácter personal	X
5.35	Revisión independiente de la seguridad de la información	X
5.36	Cumplimiento de las políticas y normas de seguridad de la información	X
5.37	Procedimientos de trabajo documentados	X
6.1	Investigación de antecedentes	X
6.2	Términos y condiciones del empleo	X
6.3	Sensibilización, educación y formación en materia de seguridad de la información	X
6.4	Proceso disciplinario	X

6.5	Responsabilidades tras el cese o el cambio de empleo	X
6.6	Acuerdos de confidencialidad o no revelación	X
6.7	Trabajo remoto	X
6.8	Informes de eventos de seguridad de la información	X
7.1	Perímetro de Seguridad física	X
7.2	Controles físicos de entrada	X
7.3	Asegurar las oficinas, salas e instalaciones	X
7.4	Vigilancia de la seguridad física	X
7.5	Protección contra las amenazas físicas y medioambientales	X
7.6	Trabajo en áreas seguras	X
7.7	Escritorio y pantalla despejados	X
7.8	Ubicación y protección de los equipos	X
7.9	Seguridad de los activos fuera de las instalaciones	X
7.10	Medios de almacenamiento	X
7.11	Servicios de apoyo	X
7.12	Seguridad del cableado	X
7.13	Mantenimiento de equipos	X
7.14	Eliminación segura o reutilización de los equipos	X
8.1	Dispositivos finales del usuario	X
8.2	Derechos de acceso privilegiados	X
8.3	Restricción del acceso a la información	X
8.4	Acceso al código fuente	X
8.5	Autenticación segura	X
8.6	Gestión de la capacidad	X
8.7	Protección contra el Malware	X
8.8	Gestión de las vulnerabilidades técnicas	X
8.9	Gestión de la configuración	X
8.10	Borrado de información	X
8.11	Enmascaramiento de datos	X
8.12	Prevencion de fuga de datos	X
8.13	Copias de Seguridad	X
8.14	Redundancia de las instalaciones de tratamiento de la información	X
8.15	Registros	X
8.16	Actividades de supervisión	X
8.17	Sincronización del reloj	X
8.18	Uso de programas de utilidades privilegiados	X
8.19	Instalación de software en sistemas operativos	X
8.20	Controles de red	X
8.21	Seguridad de los servicios de red	X
8.22	Filtrado de Web	X
8.23	Segregación de redes	X
8.24	Uso de criptografía	X
8.25	Ciclo de vida del desarrollo Seguro	X
8.26	Requisitos de seguridad de las aplicaciones	X

8.27	Arquitectura de sistemas seguros y principios de ingeniería	X
8.28	Código Seguro	X
8.29	Pruebas de seguridad en el desarrollo y la aceptación	X
8.30	Desarrollo subcontratado	X
8.31	Separación de los entornos de desarrollo, prueba y producción	X
8.32	Gestión de cambios	X
8.33	Información de prueba	X
8.34	Protección de los sistemas de información durante la auditoría y las pruebas	X

ANEXO - HOJA DE DATOS – EMISIÓN CERTIFICADO

DATOS GENERALES		¿Hay cambios respecto a datos anteriores? SI / NO
Nombre de la Organización	SPIKA TECH, S.L.	
Factoría/Planta/Delegación		
Domicilio Social	CL ALCALÁ DE GUADAÍRA, 6 6ºA, 28018 - MADRID	
C.I.F.	B87386900	
Grupo (si aplica)		

ALCANCE DEL CERTIFICADO (añadir tantas filas como traducciones sean necesarias)		¿Hay cambios respecto a datos anteriores? SI / NO
Norma de referencia	ISO/IEC 27001:2022	
Alcance Español	Los sistemas de información que dan soporte a las actividades de Diseño y desarrollo de dispositivo médico (software y sistema de adquisición de datos para uso médico-cardiológico).	
Alcance Inglés	<ALCANCE_IN>	

CENTROS DE ACTIVIDAD Y Nº PERSONAS					¿Hay cambios respecto a datos anteriores? SI / NO
Emplazamientos permanentes a incluir en el certificado (añadir tantas filas como sean necesarias)	**Pers Prop**	**Pers Subc**	**Colectivo**	**Nº**	
CL ALCALÁ DE GUADAÍRA, 6 6ºA. 28018 - MADRID					

OTRA INFORMACIÓN RELEVANTE PARA EL DIMENSIONAMIENTO DE LA AUDITORÍA			
Volumen de proyectos			
Superficie (m^2)/ nº Líneas/Nº APPCC (ISO 22000)			
Consumo anual de energía (Mwh/año) / Nº de fuentes de energía / Nº usos significativos de energía (ISO 50001)			
Nº Usuarios con privilegios de administración y gestión (ISO 27001)			
Áreas/departamentos implicados en el *Business Impact Analysis* (ISO 22301)			
Otros esquemas			

OTROS ASPECTOS DEL SISTEMA DE GESTIÓN	
Sistema de Gestión integrado	SI ☐ NO ☐
Grado de integración (en %)	

ANEXO - HOJA DE DATOS – CONTACTOS Y DIRECCIONES

CONTACTOS Y DIRECCIONES		¿Hay cambios respecto a datos anteriores? SI / NO
Contacto Principal		
Nombre	D. CARLOS ZÚÑIGA ARNAU	
Cargo	<CARGO_CONTACTO>	
Teléfono	676367467	
Correo electrónico	carlosz@spikatech.com	
Dirección Envío Correspondencia	CL ALCALÁ DE GUADAÍRA, 6 6ºA 28018 - MADRID	
Contacto Envío Certificado		
Nombre	D. CARLOS ZÚÑIGA ARNAU	
Cargo	<CARGO_CONTACTO_CERTIFICADO>	
Teléfono	676367467	
Correo electrónico	carlosz@spikatech.com	
Dirección Envío Certificado	CL ALCALÁ DE GUADAÍRA, 6 6ºA 28018 - MADRID	
Contacto de Facturación (entrega factura)		
Nombre	ZÚÑIGA ARNAU, CARLOS	
Cargo		
Teléfono	+34676367467	
Correo electrónico	carlosz@spikatech.com	
Contacto de contabilidad (pago facturas)		
Nombre	ZÚÑIGA ARNAU, CARLOS	
Cargo		
Teléfono	+34676367467	
Correo electrónico	carlosz@spikatech.com	